

Legal Boundaries & Engagement Tooling

Tooling for structure

`Faraday / Dradis` – centralize findings, assets, evidence

`Ghostwriter` (SpecterOps) – report generation + tracking

`CherryTree / Obsidian` – private notes that link

`Keep`: scope doc, RoE, scan outputs, screenshots, command logs, session IDs

Store evidence with hashes. If a client disputes a finding, your evidence must survive inspection.

Evidence discipline

Save raw nmap/curl output (not just summaries)

Timestamp every action (your command history matters)

Record DURING, not after (memory is unreliable)

Legal traps (real cases)

Scanning a range you "assumed" was in scope

Exfiltrating more than needed for proof ("pwned data")

Social engineering a helpdesk employee without authorization

Running a destructive DoS that breaks the client's prod

Publishing client findings publicly without consent

Every one of these has ended a career. The fix is the same: `written scope, minimal action, evidence, discretion.`

The authorized boundary check

Before any test step ask:

Does the RoE authorize this target?
Does the RoE authorize this technique?
Is this necessary to prove the finding?
Will this action be reversible/clean?

If any answer is no – stop, ask, document.

After the engagement

Deliver the report

Clean up any test artifacts (in scope!)

Rotate/retire test credentials

Mutual close-out: what did we find, what changed, what's next?

A pentester's career is a graveyard of people who got the shell but forgot the scope. Professionalism is 30% skill and 70% boundaries.

[← Reporting & Professional Com...](#)

Module complete ✓